UNIVERSITI TEKNOLOGI MARA
FINAL EXAMINATION

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 4 printed pages

© Hak Cipta Universiti Teknologi MARA

PART A (80 MARKS)

QUESTION 1

a) Explain two characteristics of Trojan horse malware, including how it presents itself to users and what it does once active on a host.

(2 marks)

b) State six techniques by which malware attacks and propagates, covering how virus code is attached to or substituted for a program's entry point, how early viruses spread through boot sectors, and how a worm used a mail service flaw to spread across a network.

(6 marks)

QUESTION 2

a) Explain the two stages of the biometric authentication process and state what activities occur within each stage.

(2 marks)

b) Biometric technologies are increasingly deployed as an alternative to passwords. Explain the categories of biometric applications and the characteristics and drawbacks of the specific biometric technologies discussed in the course.

(6 marks)

QUESTION 3

a) State TWO (2) key security models listed under formal security models in the lecture.

(2 marks)

b) Explain the access control structures used to implement access policies, covering the access control matrix, access control lists and capabilities, and state the requirements such structures must satisfy.

(6 marks)

QUESTION 4

a) Explain how a buffer overflow arises in a program such as the one using strcpy() into a fixed-size local buffer, and state what an attacker can achieve by exploiting it.

(2 marks)

b) State six Windows security mechanisms or components, identifying for each what it does within the Windows security architecture.

(6 marks)

QUESTION 5

© Hak Cipta Universiti Teknologi MARA

a) Explain how spyware and adware differ in the harm they cause, identifying for each the security objective from the CIA triad that is affected.

(2 marks)

b) Refer to your answer in (a). Based on the scenario in (a), justify how the Samy worm's use of cross-site scripting allowed it to spread automatically, giving six distinct points about its injection, propagation and impact.

(6 marks)

QUESTION 6

a) Explain the difference between morals, ethics and laws as three forms of guidance for conduct, giving the defining characteristic of each.

(2 marks)

b) Discuss how a professional code of ethics and conduct guides a computing professional's behaviour, referring to the ACM code and the professional bodies that maintain such codes. Support your discussion with six distinct points.

(6 marks)

QUESTION 7

a) State TWO (2) facts about the chain of trust in the Trusted Computing architecture, including how measurements are recorded and where the chain begins.

(2 marks)

b) Describe the two primary system components of the Next Generation Secure Computing Base (NGSCB), explaining the role of each component and how they relate to one another.

(6 marks)

QUESTION 8

a) State TWO (2) typical locations where network-based IDS sensors are placed in a network architecture.

(2 marks)

b) Compare the preventive roles of a firewall and a remote access VPN in network security, and explain how an intrusion detection system complements these preventive mechanisms. Provide six distinct points.

(6 marks)

QUESTION 9

a) List TWO (2) advantages of having an organizational ethical code that clarify how technology professionals should behave.

(2 marks)

© Hak Cipta Universiti Teknologi MARA

b) Describe six responsibilities that information specialists and general users carry when handling data within ethical, moral and legal constraints, and explain why merely describing these moral and ethical dimensions of ICT is not sufficient for organizational privacy protection.

(6 marks)

QUESTION 10

a) List TWO (2) password security controls that can be applied to protect password files and user accounts.

(2 marks)

b) Explain how single sign-on reduces the burden of authentication for users, and describe how Kerberos and smart cards support authentication in distributed environments.

(6 marks)

PART B (20 MARKS)

QUESTION 1

a) Discuss five ways in which intrusion detection and related defensive mechanisms can help detect and defend against malware attacks on the company's systems.

(5 marks)

b) Explain five classes of threats to information systems and, for each class, identify the security service that counters it.

(5 marks)

QUESTION 2

a) State the four goals of access control and explain the role of a reference monitor in authorization. Then describe how the Chinese Wall policy constrains a consultant's access to company information, and explain why this policy is described as history-sensitive.

(5 marks)

b) Explain the Chinese Wall policy as a formal security model, covering the two rules that govern read and write access, the type of policy it is classified as, and the specific problem it was designed to solve.

(5 marks)

END OF QUESTION PAPER

© Hak Cipta Universiti Teknologi MARA